
NIC26

Tales from Incident Response

“It’s Probably Nothing” (Until It Is)

Mikael Nyström & Hasain Alshakarti

NIC26

@mikael_nystrom
https://deploymentbunny.com
https://www.truesec.com

MVP for 23 years
Incident Responder at Truesec CSIRT
Recover/Rebuild infrastructure



NIC26

Microsoft Most Valuable Professional

DeploymentBunny.com

Hasain "The Wolf" Alshakarti
Principal Cyber Security Advisor
https://www.truesec.com

30+ years in security & infrastructure
16 years Enterprise Security MVP
Incident response, penetration testing, identity, PKI & network security



NIC26

MVP Microsoft Most Valuable Professional

Six cases. Sixty minutes. What could go wrong?

- Patching, with a side of admin credentials
- Logs with a talent for keeping secrets
- One admin account. The all-access tour
- Backups, now with attacker access
- The Forgotten POC. Still clocking in
- The system that came back from the dead

John was going to fix everything

02:57

The last server was patched.
John could finally call it a night.

07:08

The first ransom note appeared.
Someone else appreciated his work.

The administrator who patched everything

- Manual patching over RDP
- High-value credentials on each server
- More than 16 hours of work



NIC26

The outcome in this case

- Ransomware within four hours
- Primary systems back within two weeks
- Some systems took six months
- The organization lost data



Safer administrative access

- Automated patching
- Isolated privileged administration
- Tiering and controlled logon paths
- Monitoring of administrative activity



Where did those admin credentials go?

Kim had a plan for logging

The plan

Kim knew the logging had gaps.
He had a plan to put it right.

But first...

Just a few other things to fix.
Then he would get to the logs...

“Of course we have logging”

- Firewall, VPN, Windows and cloud
- Logs stayed on individual systems
- An intrusion left unanswered questions



NIC26

The investigation hit a limit

- The source reports insufficient evidence
- The initial compromised host remained unknown
- The entry point remained unknown



Usable evidence after an incident

- Logs collected beyond the source system
- Protection against deletion and alteration
- Consistent clocks across systems
- Retention matched to investigation needs



How many of your systems only log locally?

Bob had everything under control

One click

Bob was a great consultant with plenty of customers. He sold them on an RMM tool.

One click, and he could run tools on all their computers. Life was good.

Then the calls

One customer reported ransomware. Then another. Then more.

Bob began to see what they all had in common.

Him...

One admin identity across platforms

- Domain Admin in Active Directory
- Global Admin in the cloud
- Administrator in vSphere
- Administrative access from a user endpoint



NIC26

One compromise reached several layers

- Password spraying compromised the account
- The attacker encrypted VMs using a GPO
- VMware storage was also affected
- Recovery was incomplete and data was lost



Separate administrative boundaries

- Isolated administrative logons
- Separate access to backup and hypervisors
- Privileged workstations for each environment
- Least privilege for service accounts



What else can one admin account reach?

Mike had the perfect backup

All sorted

Mike ran Veeam on a domain-joined VM. Easy agent rollout. Easy backups.

A large NAS outside the domain, with a username and password. Perfect.

Saturday

Morning. Everything down. Ransomware.

Mike stayed calm. He had backups.

Except the NAS password was the same one he used on other systems...

The backup that could not restore

- Backup server in a workgroup
- Backup data on NAS devices
- NAS credentials reused elsewhere



NIC26

The attacker reached the backup storage

- The attacker discovered the NAS devices
- The attacker erased data and installed backdoors
- Many functions required rebuilding
- Some VMs survived by chance



Recovery depends on isolation

- Separate backup authentication
- Restricted access to backup storage
- Protection for recovery copies
- An end-to-end restoration exercise



Can recovery survive a stolen admin account?

Peter moved to next project

Trial over

Peter opened an online MDM trial and installed agents on a few PCs. The test went fine. They never bought licences.

The portal seemed dead. Peter moved on. The agents kept calling home. Parts of the portal still worked.

Access granted

An attacker kept trying to log in. The portal logged attempts and raised warnings. No paid licence. No alerts delivered.

Eventually, the attacker got in. That “test PC” was a jump host to every customer’s systems...

The Forgotten POC

- Jump host for a internal team
- External MDM agent for a POC
- POC forgotten.
- Agent still connects.



Logged attempts, no warnings

- Internet-facing MDM portal for the POC
- Repeated failed logins over a long period
- The MDM platform logs every attempt
- No payment, no alert emails or log delivery
- Eventually, the attacker gains access
- All customers, hosting, email and applications



NIC26

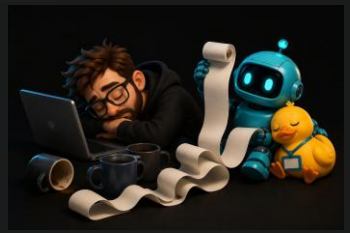
POC ownership and access limits

- An owner and an end date for every POC
- Removal of agents and access after testing
- Verified alert delivery when subscriptions end
- Separate access boundaries for each customer



NIC26

/10 12:55:00	[redacted] compromised via MDM platform
/11 20:29:39	Persistent remote access to [redacted]
/14 15:06:35	[redacted] domain compromise and Cobalt Strike on several computers
/14 18:00:00	Attempted to access 8 different customers
/23 14:15:24	Exfiltration from [redacted] domain servers started
/26 11:42:05	Enumerated AD in [redacted]
/26 15:56:52	Accessed hypervisors [redacted]
/26 20:42:46	Jumped into customer [redacted] to steal credentials
/27 19:09:00	Jumped into customer [redacted] to steal credentials and install backdoors
/27 19:56:15	[redacted] domain compromise
/29 16:53:58	[redacted] domain compromise
/29 17:48:26	Script used to steal credentials from all [redacted] servers
/29 19:53:12	[redacted] Active Directory dump
/30 14:04:28	Continued attack
/02 01:30:00	Proper isolation of the [redacted] environment



NIC26

What can your forgotten POC still reach?

Anders had switched it off

Retired

Anders managed many VMs, one host at a time. No redundancy, no UPS, no high availability.

An old Windows Server 2003 still exposed RDP to the Internet. Nobody needed it anymore. Anders shut it down. Job done.

Six years later

A power cut. The hosts restarted. So did the VMs, even the ones that had been off.

Server 2003 was back. Every firewall rule was still there. RDP was open to the Internet again.

Anders was about to have a bad day.

The system that came back from the dead

- Windows Server 2003 with public RDP
- Shutdown after discovery
- No cluster or workload mobility
- No host patching or UPS



NIC26

A restart exposed the entire domain

- Power outage restarts the retired VM
- Domain membership and firewall rules remain
- Internet scanning finds its unpatched RDP
- Ready-made tools give the attacker access
- Lateral movement leads to Domain Admin
- GPO deploys encryption across all servers



Complete decommissioning

- Removal of retired VMs and domain accounts
- Removal of obsolete firewall rules
- Verified VM startup settings after power loss
- A maintenance plan that allows host patching
- UPS protection and controlled shutdown



NIC26

Which retired system could restart tonight?

Patterns across six cases

- Privileged logons spread credential exposure
- Local logs left gaps in the evidence
- Shared identities crossed platform boundaries
- Reachable backups lost their protection
- A forgotten POC exposed every customer
- An incomplete retirement reopened domain access

Your next review

- Trace one privileged administration path
- Retrieve evidence from a separate log store
- Map shared identities across platforms, lateral movement paths
- Restore a service from protected copies
- Find forgotten agents/applications/systems and decommission
- Verify retired systems cannot restart or reconnect, and archive

Questions

Mikael Nyström & Hasain Alshakarti

NIC26